

NETWORK AND SECURITY FOUNDATIONS

Class Notes

Sessions 1–5

Cybersecurity Leadership • Control Types • Patch Management • Threat Actors • Active Threats

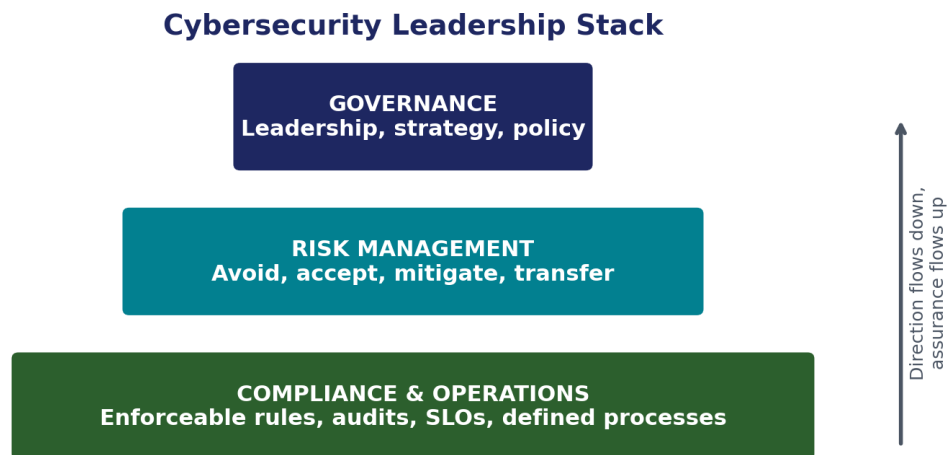
Session 1: Understanding Cybersecurity Leadership Concepts

LEARNING OBJECTIVE

Understand the role of cybersecurity leadership, focusing on governance, risk, and compliance principles.

1.1 Policy and Governance

Governance gives security work a direction. Leaders set strategy, then translate strategy into written policy. Policy turns intent into enforceable rules.



Why policy matters

- **Establishes priorities:** Policies establish organizational priorities.
- **Enforceable rules:** Rules must be specific enough to enforce.
- **Audit baseline:** Auditors measure the organization against its written policies.

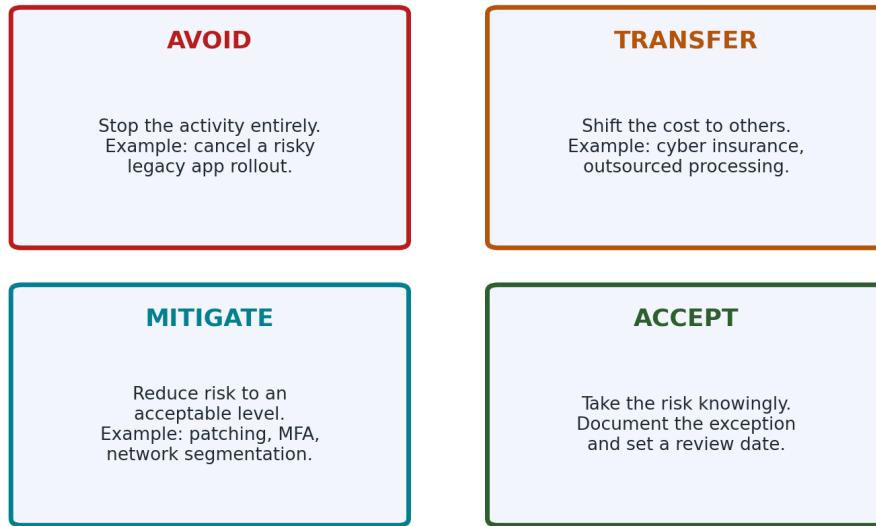
Security operations

- Well-defined processes keep daily work consistent and repeatable.
- Service Level Objectives (SLOs) set measurable targets for security services.

1.2 Risk Management Principles

Every risk gets one of four responses. Pick the response based on cost, impact, and business priorities.

Four Risk Responses



You manage risk. You never eliminate risk.

Mitigate and accept in practice

- Reduce each risk to a level the business considers acceptable.
- You manage risk. You never eliminate risk.
- Document every decision. Documentation proves due diligence.
- Risk exceptions need specific dates for follow-up actions. An exception without a review date becomes permanent by accident.

1.3 Threat Modeling

Threat modeling identifies who attacks you, how they attack, and which defenses stop them.

Threat Modeling Workflow



Identify specifics

- **Threat actors:** Name the threat actors who target your industry.
- **TTPs:** Study their tactics, techniques, and procedures.

- **Prioritization:** Different threat groups target different organizations. Prioritize the groups most likely to target you, then build defenses against their methods.

Collaboration requirement

One person never holds all the knowledge a threat model needs. Effective models combine five knowledge areas:

- System components and architecture
- Potential attack methods
- Effective and appropriate mitigation techniques
- Legal and regulatory frameworks
- Impacts on business operations

1.4 Class Activity: Cybersecurity Policy Development

Work in groups of 3 to 4 students. Draft a policy statement, identify governance elements, and justify your decisions for three scenarios:

- Selecting appropriate technologies for cybersecurity initiatives
- Incident response and risk management adjustments
- Employee cybersecurity training and awareness

KEY TAKEAWAYS

- Governance connects leadership strategy to enforceable policy.
- Four risk responses exist: avoid, accept, mitigate, transfer.
- Risk exceptions require documented follow-up dates.
- Threat models deconstruct systems to find attack points and map mitigations.

Session 2: Exploring Control Types and Methods

LEARNING OBJECTIVE

Analyze security controls and their application in organizational security frameworks.

2.1 Security Control Categories

Security controls protect assets. Technology alone falls short. A balanced defense combines controls from three categories.

Three Control Categories, One Balanced Defense



Common gap: overreliance on technical and preventive controls

2.2 Security Control Functional Types

Each control also serves a functional objective. Match each objective to a concrete example:

Control Objective	What the control does	Example
Preventive	Blocks the attack before damage occurs	Firewall drop rule, access control lists (ACLs)
Detective	Reveals the attack during or after the event	Logs, intrusion detection alerts
Corrective	Restores systems after an incident	Backup system
Responsive	Guides the immediate reaction	Course of Action (CoA)
Compensating	Covers a gap another control leaves open	Audit

Mapping exercise

Build a grid of categories against objectives. For each asset, ask two questions:

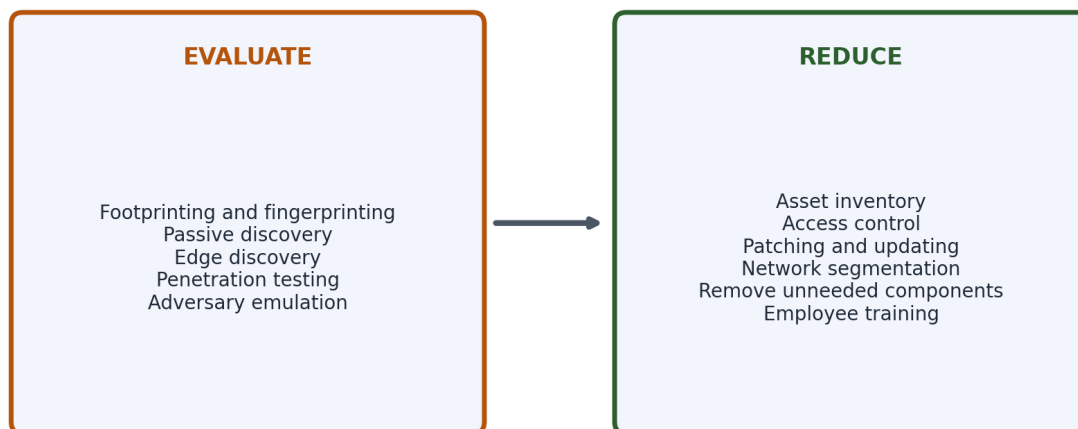
- Does protection cover this asset across all control types?
- Do controls in each category meet all security objectives?

Common gap: overreliance on technical and preventive controls. Organizations buy tools, then skip the audits, training, and response plans those tools depend on.

2.3 Managing Attack Surfaces

The attack surface describes your level of exposure. Mapping the surface reveals weak spots across people, processes, software, and devices.

Evaluate the Surface, Then Shrink the Surface



KEY TAKEAWAYS

- Three control categories: technical, operational, managerial.
- Five functional types: preventive, detective, corrective, responsive, compensating.
- Map controls to assets to expose coverage gaps.
- Evaluate the attack surface first, then shrink the surface.

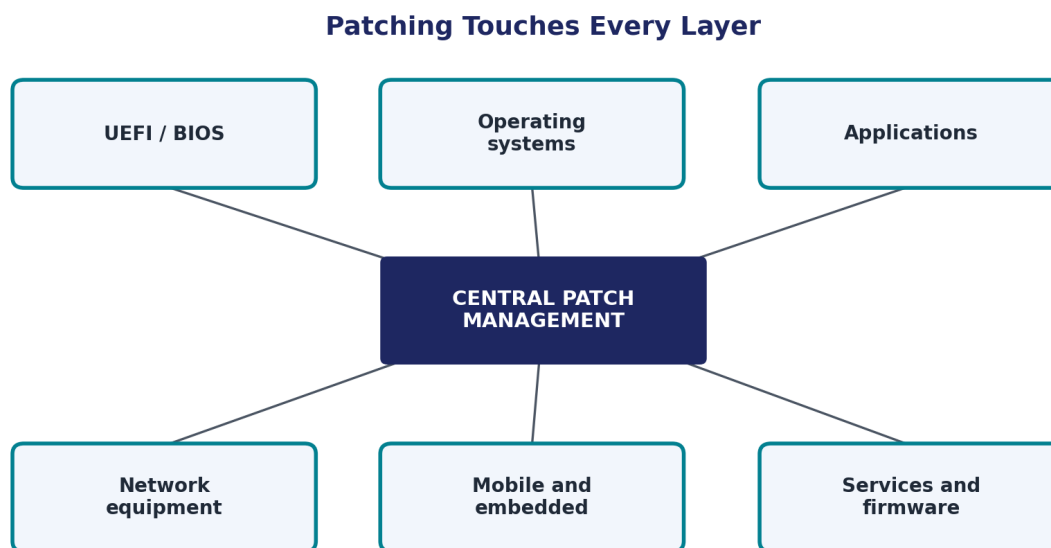
Session 3: Explaining Patch Management Concepts

LEARNING OBJECTIVE

Explain the importance of patch management and configuration management for security and stability.

3.1 Software Patching and Host Protections

Patching consumes time and demands central management. Compliance frameworks require proof of regular patching. Diverse systems make the job harder because different platforms need different tools.



Verify the patch source. Supply chain attacks hide inside updates.

Trustworthy patching sources

Verify the source of every patch. Attackers compromise vendor update channels to deliver malware through trusted updates. This technique drives supply chain attacks.

3.2 Configuration Management

Configuration management gives you control over endpoint configuration. Define a configuration once, then apply the same configuration across many systems. This discipline anchors infrastructure as code, CI/CD, and DevOps environments.

Tool	Website
Chef	https://www.chef.io/
Puppet	https://puppet.com/
Ansible	https://www.ansible.com/

Tool	Website
Terraform	https://www.terraform.io/

3.3 Maintenance Windows

- Admins perform scheduled maintenance tasks inside routine windows.
- Windows support preventive maintenance and noncritical patch deployment.
- Every window must follow change management policies.
- Tune monitoring tools to recognize maintenance windows. Alert noise during a window hides real attacks.
- Savvy attackers strike during maintenance windows because defenders expect anomalies at those times.

KEY TAKEAWAYS

- Patch every layer: firmware, OS, applications, network gear, mobile, embedded.
- Verify patch sources to block supply chain attacks.
- Configuration management applies one definition across many systems.
- Maintenance windows need change management and monitoring awareness.

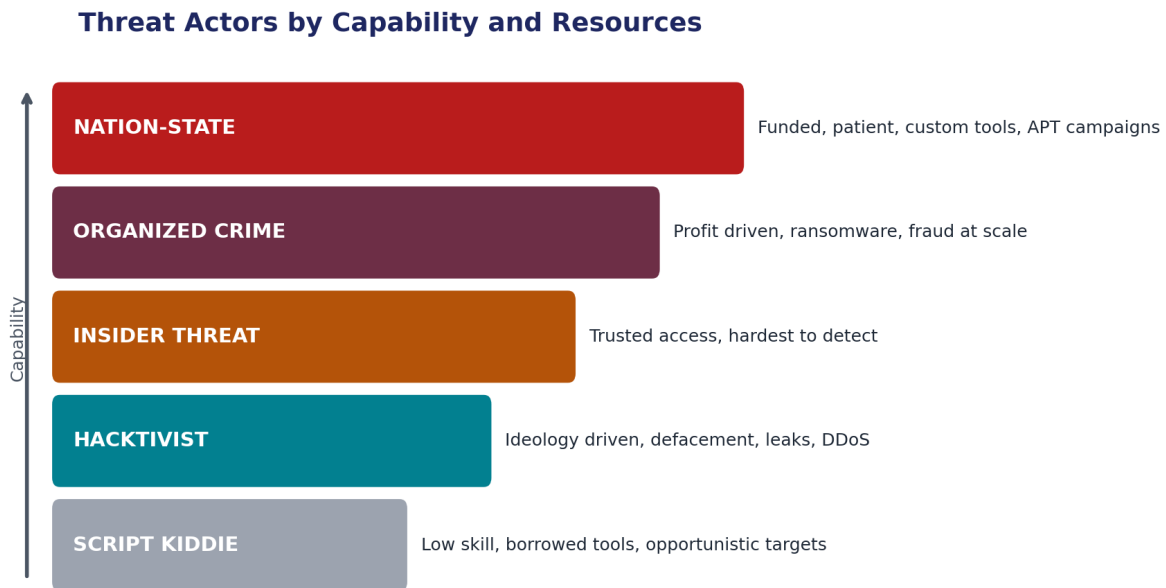
Session 4: Exploring Threat Actor Concepts

LEARNING OBJECTIVE

Differentiate between various threat actors and utilize intelligence platforms to monitor threats.

4.1 Threat Actor Types

Six actor types appear in this course. Each differs in skill, funding, motivation, and access.



Supply chain access cuts across all five tiers. Any actor with a foothold inside a vendor reaches every customer of the vendor at once.

4.2 Advanced Persistent Threat (APT)

APTs combine high capability with long-term persistence. Two actor types run APT campaigns:

Dimension	Details
Threat actors	Nation-state groups, organized crime
Tools	Command and control infrastructure, rootkits, custom crafted tools
Targets	Large organizations, government

4.3 Tactics, Techniques, and Procedures (TTPs)

TTPs describe the study of threat actor behavior. Two goals drive TTP analysis:

- Identify which threat actors target you.
- Understand the methods attackers use, step by step.

MITRE ATT&CK

MITRE ATT&CK organizes real-world attacker behavior into a matrix of tactics (the goals) and techniques (the methods). Defenders use the matrix to map detections, find coverage gaps, and speak a common language about attacks.

4.4 Class Activity: Threat Actor Strategy Role-Playing

Form groups of 3 students. Each student represents one actor type: nation-state, organized crime, or hacktivist. Review the scenario worksheet, then for each scenario:

- Determine the strategy and tactics your assigned actor would use.
- Identify the potential impact on the targeted organization.
- Discuss defense strategies the organization could implement.

Be ready to role-play your scenario in front of the class.

KEY TAKEAWAYS

- Actor types differ in capability: script kiddie, hacktivist, insider, organized crime, nation-state.
- APTs pair custom tooling with patient, persistent access.
- TTP analysis tells you who attacks and how.
- MITRE ATT&CK gives defenders a shared map of attacker behavior.

Session 5: Identifying Active Threats

LEARNING OBJECTIVE

Apply network diagnostic tools and techniques for identifying and resolving vulnerabilities. Integrate vulnerability analysis and remediation strategies into real-world scenarios.

5.1 Open-Source Intelligence (OSINT)

OSINT means publicly available information. Attackers harvest OSINT before touching your network. Know what they find:

- **Public sources:** Public websites, code repositories, and DNS records expose IP addresses and assigned address ranges.
- **Employee details:** Names, email addresses, phone numbers, and physical office addresses circulate freely.
- **Social media:** Facebook and LinkedIn posts or profiles reveal sensitive data about roles, tools, and projects.

HTML code as intelligence

Web page source code provides IP addresses, web server names, operating system versions, file paths, and developer or administrator names and emails. Code layout and organization reveal development practices and the level of security awareness inside the team.

Document metadata

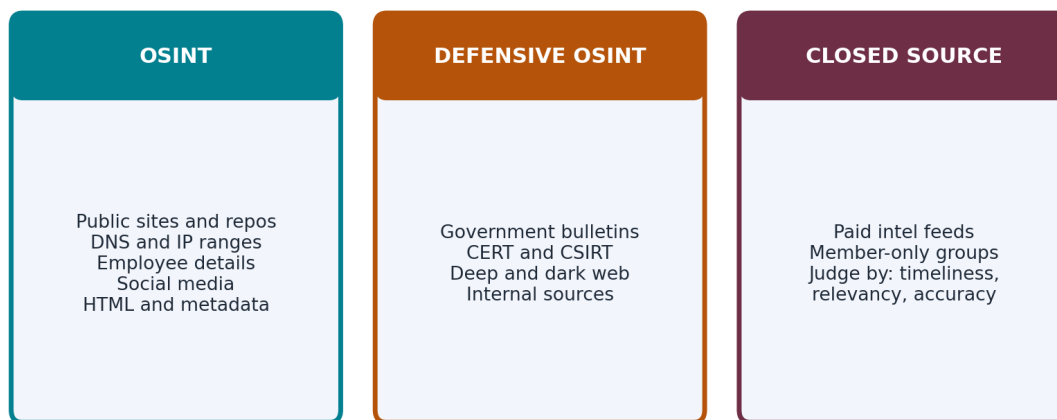
Documents hide information beyond their visible content. Metadata scans on public documents expose hidden details. FOCA (Fingerprinting Organizations with Collected Archives) finds and extracts:

- File author names and users who made changes
- Software names and version info, such as Adobe Acrobat or Office 2019
- File paths, hostnames, and usernames

5.2 Defensive OSINT and Closed Sources

Defenders run the same playbook in reverse. Defensive OSINT gathers intelligence focused on identifying threats to you.

Where Threat Intelligence Comes From



ISACs connect all three streams for critical infrastructure sectors

Closed-source intelligence includes paid threat feeds and member-only groups. Judge every feed by three attributes: timeliness, relevancy, and accuracy. Stale, off-topic, or wrong intelligence wastes analyst time.

5.3 ISACs and Intelligence Sharing

Information Sharing and Analysis Centers (ISACs) provide cybersecurity information and services for critical infrastructure teams. The DHS identifies 16 critical infrastructure sectors.

Resource	Location
US-based ISACs	https://www.nationalisacs.org/member-isacs-3
UK-based ISACs	https://ncsc.gov.uk/section/keep-up-to-date/cisp
DHS critical infrastructure sectors	https://www.dhs.gov/cisa/critical-infrastructure-sectors

Threat intelligence sharing goals

- Detect indicators of compromise (IOCs)
- Monitor threat actor activities
- Record and analyze findings
- Collaborate on defense strategies

KEY TAKEAWAYS

- Attackers build their picture of you from public data before any intrusion.
- HTML source and document metadata leak names, versions, and paths.

- Judge intelligence feeds by timeliness, relevancy, and accuracy.
- ISACs and sharing programs multiply every defender's visibility.

Quick Reference: Key Terms

Term	Definition
Governance	Leadership structure connecting strategy to policy and oversight
SLO	Service Level Objective, a measurable target for a service
Risk exception	A documented, dated acceptance of a risk outside policy
Threat model	A structured map of attack points, methods, and mitigations
TTPs	Tactics, techniques, and procedures of a threat actor
Attack surface	The total exposure an attacker sees across people, process, and tech
Compensating control	A control covering a gap another control leaves open
Configuration management	Defining a configuration once and applying everywhere
Maintenance window	A scheduled period for approved system changes
APT	Advanced Persistent Threat, a funded, patient, capable adversary
MITRE ATT&CK	A public matrix of real-world attacker tactics and techniques
OSINT	Open-Source Intelligence drawn from public information
FOCA	A tool extracting hidden metadata from public documents
IOC	Indicator of Compromise, evidence of attacker activity
ISAC	Information Sharing and Analysis Center for a critical sector